The One-Number Hack

In the video I changed one number in a link and got a stranger's bank statement.

Your app checks that you're logged in. It never checks that the thing you asked for is yours.

1 Let Claude do it

Paste it into Claude Code inside your project. It reads your code, runs the checker, and shows you the exact request that got in.

COPY THIS INTO CLAUDE CODE

```
Clone https://github.com/Yxsuf1/one-number-check and follow the skill in its
.claude/skills/one-number-check/SKILL.md to check this project for the one-
number hack. Use two test accounts on my local or staging copy, show me
proof for every hole you find, and only fix things after I say yes.
```

2 Do it yourself

Five minutes, two accounts, no tools to install.

1. **Make two accounts.**
   Call them A and B. Use two browsers, or one normal window and one private window.

2. **As B, make something private.**
   An order, a note, an invoice, an upload. Copy its link.

3. **As A, open B's link.**
   If you can see B's stuff, that's the hack. You just did it.

4 No number in the link?

Press F12, open the Network tab and click around as B until you see a request with an ID in it. Note B's ID. Do the same as A, right-click A's request, Copy as fetch, paste it into the Console tab, swap in B's ID, press Enter.

5 Push it further.

Try editing and deleting B's thing the same way. Then log out and try again.

PASS
You get "not found" or "not allowed" every single time.

FAIL
You see, change or delete B's data even once.

Found one? Paste this into Claude, Cursor or Lovable:

COPY THIS INTO YOUR AI TOOL

```
Go through every route, API endpoint, server action and database query in
this app that takes an ID from the user. Make sure the server checks that
the logged-in user is allowed to read, update or delete that record. Never
trust an ID or user id sent from the browser. If this app uses Supabase:
turn on Row Level Security for every table, drop policies that allow all
rows (like using (true)) unless that table is meant to be public, and give
private tables select, insert, update and delete policies tied to
auth.uid(). Keep anything that's meant to be public or shared working. Then
write a test where user A tries to read, edit and delete user B's records,
and to create a record with B's user id, and make it pass.
```

Then do the five-minute test again yourself. Don't take the AI's word for it.

Hack your site

Get your own app tested for real holes, with the proof and the fix. Join the waitlist.

vaultxsec.com/hack-my-app

Learn to hack

Breach Lab: a free 20-minute lab. Hack an invoice app on your phone.

vaultxsec.com/lab

Only test apps you own or have written permission to test.